

Remediation delle vulnerabilità critiche – Metasploitable 2

Studente: Vincenzo Lembo

Corso: Cybersecurity & Ethical Hacking

Esercitazione: W12D4 progetto finale

Argomento: Vulnerability Remediation con Nessus

Ambiente: Metasploitable 2, Kali Linux – UTM

1. Obiettivo

L'obiettivo di questa fase è implementare azioni di remediation sulle vulnerabilità critiche selezionate durante la scansione iniziale effettuata con Nessus.

Le vulnerabilità selezionate sono:

- **VNC Server 'password' Password – Plugin ID 61708**
- **Bind Shell Backdoor Detection – Plugin ID 51988**

Per ciascuna vulnerabilità sono state applicate modifiche direttamente sul sistema Metasploitable 2 e successivamente sono state effettuate verifiche tecniche per accertare la corretta applicazione delle modifiche.

2. Remediation – VNC Server 'password' Password

2.1 Vulnerabilità

Nessus ha rilevato che il servizio VNC sulla porta TCP 5900 utilizzava la password debole **password**, consentendo l'autenticazione al servizio mediante una credenziale facilmente prevedibile.

La remediation scelta consiste nella sostituzione della password VNC con una password differente e più robusta.

2.2 Modifica della password VNC

```
sudo vncpasswd /root/.vnc/passwd
```

Il comando **vncpasswd** è stato utilizzato per modificare le credenziali associate al servizio VNC.

Durante la procedura è stata inserita e confermata una nuova password. Il sistema ha inoltre richiesto l'eventuale configurazione di una password "view-only".

```
msfadmin@metasploitable:~$ sudo vncpasswd /root/.vnc/passwd
[sudo] password for msfadmin:
Password:
Warning: password truncated to the length of 8.
Verify:
Would you like to enter a view-only password (y/n)? y
Password:
Warning: password truncated to the length of 8.
Verify:
msfadmin@metasploitable:~$
```

2.3 Verifica del servizio VNC

Abbiamo inoltre verificato l'accesso tramite Kali:

```
nmap -p 5900 192.168.50.101
```

ottenendo:

```
5900/tcp open  vnc
```

```
(kali㉿kali)-[~]
└─$ nmap -p 5900 192.168.50.101
Starting Nmap 7.99 ( https://nmap.org ) at 2026-10-02 12:48 -0400
Nmap scan report for 192.168.50.101
Host is up (0.0024s latency).

PORT      STATE SERVICE
5900/tcp  open  vnc
MAC Address: 96:95:E1:A3:BA:9F (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 4.15 seconds
```

La verifica mediante Nmap ha confermato che la porta TCP 5900 è rimasta aperta e che il servizio VNC continua a essere disponibile.

L'obiettivo della remediation, infatti, non era disabilitare il servizio VNC, ma eliminare l'utilizzo della password debole rilevata da Nessus.

3. Remediation – Bind Shell Backdoor Detection

3.1 Vulnerabilità

Nessus ha individuato una Bind Shell sulla porta **TCP 1524**. Il servizio consentiva l'esecuzione remota di comandi con privilegi **root** senza un normale meccanismo di autenticazione.

La remediation ha quindi avuto come obiettivo la disabilitazione del servizio responsabile dell'apertura della porta TCP 1524.

3.2 Identificazione del servizio

Abbiamo inizialmente verificato la porta con:

```
sudo netstat -tulpn | grep 1524
```

Il risultato mostrava:

```
0.0.0.0:1524 LISTEN xinetd
```

```
msfadmin@metasploitable:~$ sudo netstat -tulpn | grep 1524
[sudo] password for msfadmin:
tcp        0      0 0.0.0.0:1524        0.0.0.0:*          LISTEN
#606/xinetd
msfadmin@metasploitable:~$
```

Poi abbiamo individuato la configurazione responsabile attraverso:

```
sudo grep -R "1524\|ingreslock" /etc 2>/dev/null
```

ottenendo, tra le altre informazioni:

```
/etc/services:ingreslock 1524/tcp
```

```
/etc/services:ingreslock 1524/udp
```

```
/etc/inetd.conf:ingreslock stream tcp nowait root /bin/bash bash -i
```

```
msfadmin@metasploitable:~$ sudo grep -R "1524\|ingreslock" /etc 2>/dev/null
/etc/services:ingreslock      1524/tcp
/etc/services:ingreslock      1524/udp
/etc/inetd.conf:ingreslock stream tcp nowait root /bin/bash bash -i
msfadmin@metasploitable:~$
```

L'analisi ha permesso di individuare nel file `/etc/inetd.conf` una configurazione relativa al servizio `ingreslock`, associato alla porta 1524.

La configurazione avviava `/bin/bash` con privilegi root, determinando l'esposizione della Bind Shell rilevata da Nessus.

3.3 Disabilitazione della Bind Shell

```
ingreslock stream tcp nowait root /bin/bash bash -i
```

è stata commentata ottenendo:

```
#ingreslock stream tcp nowait root /bin/bash bash -i
```

La verifica è stata effettuata con:

```
grep ingreslock /etc/inetd.conf
```

La direttiva relativa alla Bind Shell è stata disabilitata commentando la relativa riga all'interno del file `/etc/inetd.conf`.

```
msfadmin@metasploitable:~$ grep ingreslock /etc/inetd.conf
#ingreslock stream tcp nowait root /bin/bash bash -i
msfadmin@metasploitable:~$
```

3.4 Riavvio di xinetd

Successivamente abbiamo eseguito:

```
sudo /etc/init.d/xinetd restart
```

ottenendo:

```
* Stopping internet superserver xinetd  [ OK ]
```

```
* Starting internet superserver xinetd  [ OK ]
```

Il servizio `xinetd` è stato riavviato affinché la modifica alla configurazione diventasse effettiva.

3.5 Verifica finale della porta 1524

Infine:

```
sudo netstat -tulpn | grep 1524
```

Questa volta **non ha restituito alcun risultato**.

Dopo il riavvio di `xinetd`, il controllo della porta TCP 1524 non ha restituito alcun processo in ascolto.

Ciò conferma che la Bind Shell non risulta più esposta attraverso la porta 1524.

```
hsfadmin@metasploitable:~$ sudo /etc/init.d/xinetd restart
* Stopping internet superserver xinetd          [ OK ]
* Starting internet superserver xinetd          [ OK ]
hsfadmin@metasploitable:~$ sudo netstat -tulpn | grep 1524
hsfadmin@metasploitable:~$
```

4. Conclusioni

Sono state implementate azioni di remediation sulle due vulnerabilità critiche selezionate. Per il servizio VNC è stata sostituita la password debole, mantenendo attivo il servizio sulla porta TCP 5900. Per la Bind Shell è stata individuata e disabilitata la configurazione responsabile dell'esposizione della porta TCP 1524. Le verifiche locali hanno confermato la corretta applicazione delle modifiche. Per verificare anche l'efficacia delle remediation dal punto di vista del vulnerability scanner, è stata successivamente eseguita una nuova scansione Nessus utilizzando le stesse impostazioni della scansione iniziale.

Vincenzo Lembo